

COMPREHENSIVE PENETRATION TESTING REPORT

DVWA Capstone Assessment

Prepared By: Neeshant Sangwan

Executive Summary

A penetration test was performed against a DVWA environment. Testing identified Command Injection, Brute Force Authentication weaknesses, Security Misconfiguration, and exposed services. Evidence was collected using DVWA, Nmap, and Wireshark. Findings were mapped to OWASP Top 10 and prioritized using CVSS scoring.

Assessment Environment

The screenshot displays the DVWA Security page in a web browser. The address bar shows 'localhost/DVWA-master/security.php'. The page has a dark header with the DVWA logo and a navigation menu on the left. The main content area is titled 'DVWA Security' with a lock icon. Below the title, the 'Security Level' is indicated as 'low'. A text block explains that the security level can be set to low, medium, high, or impossible, and that it changes the vulnerability level of DVWA. A list of four levels is provided: 1. Low (completely vulnerable, no security measures), 2. Medium (example of bad security practices), 3. High (extension to medium difficulty, harder or alternative bad practices), and 4. Impossible (secure against all vulnerabilities). A dropdown menu is set to 'Low' with a 'Submit' button. Below this, under 'Additional Tools', there is a link to 'View Broken Access Control Logs'. At the bottom, a box confirms 'Security level set to low'. The footer shows the user is 'admin' and the security level is 'low'.

localhost/DVWA-master/security.php

DVWA Security

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

Low Submit

Additional Tools

- [View Broken Access Control Logs](#) - View access logs for the Broken Access Control vulnerability

Security level set to low

Username: admin
Security Level: Security Level: low
Local: en

Command Injection Source Review

localhost/DVWA-master/security.php



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Logout

DVWA Security

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

Low

Submit

Additional Tools

- [View Broken Access Control Logs](#) - View access logs for the Broken Access Control vulnerability

Security level set to low

Username: admin
Security Level: Security Level: low
Locale: en

Brute Force Authentication

localhost/DVWA-master/vulnerabilities/brute/?username=admin&password=password&Login=Login#



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Logout

Vulnerability: Brute Force

Login

Username:

Password:

Welcome to the password protected area admin



More Information

- https://owasp.org/www-community/attacks/Brute_force_attack
- <https://www.golinuxcloud.com/brute-force-attack-web-forms>

Username: admin
Security Level: Security Level: low
Locale: en

View Source

View Help

Command Injection Module

localhost/DVWA-master/vulnerabilities/exec/#



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
Pinging 127.0.0.1 with 32 bytes of data:
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128

Ping statistics for 127.0.0.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

More Information

- <https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
- <http://www.ss64.com/bash/>
- <http://www.ss64.com/nt/>
- https://owasp.org/www-community/attacks/Command_Injection

Username: admin
Security Level: Security Level: low
Locale: en

Successful Command Execution

localhost/DVWA-master/vulnerabilities/exec/#



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
Pinging 127.0.0.1 with 32 bytes of data:
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128

Ping statistics for 127.0.0.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms

Windows IP Configuration

Wireless LAN adapter Local Area Connection* 1:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Wireless LAN adapter Local Area Connection* 2:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Wireless LAN adapter Wi-Fi:

    Connection-specific DNS Suffix  . :
    Link-local IPv6 Address . . . . . : fe80::5b67:201b:358:52e3%15
    IPv4 Address. . . . . : 192.168.0.103
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.0.1

Ethernet adapter Ethernet:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :
```

More Information

- <https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
- <http://www.ss64.com/bash/>
- <http://www.ss64.com/nt/>

Security Configuration

localhost/DVWA-master/vulnerabilities/exec/#

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Logout

Username: admin

Security Level: Security Level

Locale: en

SQLi DB: mysql

Pinging 127.0.0.1 with 32 bytes of data:
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128

Ping statistics for 127.0.0.1:
Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
Minimum = 0ms, Maximum = 0ms, Average = 0ms

Windows IP Configuration

Wireless LAN adapter Local Area Connection* 1:

Damn Vulnerable Web Application (DVWA)Source :: Damn Vulnerable Web Application (DVWA) - Brave

localhost/DVWA-master/vulnerabilities/view_source.php?id=exec&security=low

Command Injection Source

vulnerabilities/exec/source/low.php

```
<?php
if( isset( $_POST[ 'Submit' ] ) ) {
    // Get input
    $target = $_REQUEST[ 'ip' ];

    // Determine OS and execute the ping command.
    if( striistr( php_uname( 's' ), 'Windows NT' ) ) {
        // Windows
        $cmd = shell_exec( 'ping ' . $target );
    }
    else {
        // *nix
        $cmd = shell_exec( 'ping -c 4 ' . $target );
    }

    // Feedback for the end user
    echo "<pre>{$cmd}</pre>";
}

?>
```

Compare All Levels

Damn Vulnerable Web Application (DVWA)

Security Verification

localhost/DVWA-master/



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Logout

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

More Training Resources

DVWA aims to cover the most commonly seen vulnerabilities found in today's web applications. However there are plenty of other issues with web applications. Should you wish to explore any additional attack vectors, or want more difficult challenges, you may wish to look into the following other projects:

- [Mutillidae](#)
- [OWASP Vulnerable Web Applications Directory](#)

Nmap Enumeration

```
C:\WINDOWS\system32\cmd. X + v
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
1042/tcp  open  afrog
7778/tcp  open  interwise

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds

C:\Users\Neeshant.S>nmap -sV localhost
Starting Nmap 7.991 ( https://nmap.org ) at 2026-09-16 19:14 +0530
Warning: Hostname localhost resolves to 2 IPs. Using 127.0.0.1.
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000048s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
445/tcp   open  microsoft-ds?
1042/tcp  open  afrog?
7778/tcp  open  interwise?
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.36 seconds

C:\Users\Neeshant.S>nmap -0 localhost
nmap: illegal option -- 0
See the output of nmap -h for a summary of options.

C:\Users\Neeshant.S>
```

Wireshark Analysis

The image displays the Wireshark network traffic analysis interface. The top pane shows a list of captured packets with columns for No., Time, Source, Destination, Protocol, and Length. The bottom pane shows the detailed view of the selected packet (No. 1), which is a TCP packet from 192.168.0.103 to 192.168.0.103, port 443 to 1451, Seq=226, Ack=2657, Win=32256, Len=0.

No.	Time	Source	Destination	Protocol	Length	Info
413	65.127184400	34.229.35.39	192.168.0.103	TCP	54	443 → 1511 [ACK] Seq=226 Ack=2657 Win=32256 Len=0
414	65.127187000	34.229.35.39	192.168.0.103	TLSv1.3	233	Application Data
415	65.127188400	34.229.35.39	192.168.0.103	TLSv1.3	252	Application Data
416	65.127189100	34.229.35.39	192.168.0.103	TCP	54	443 → 1511 [FIN, ACK] Seq=603 Ack=2657 Win=32256 Len=0
417	65.127373300	192.168.0.103	34.229.35.39	TCP	54	1511 → 443 [ACK] Seq=2657 Ack=604 Win=64768 Len=0
418	65.128410000	192.168.0.103	34.229.35.39	TLSv1.3	78	Application Data
419	65.129222700	192.168.0.103	34.229.35.39	TCP	54	1511 → 443 [FIN, ACK] Seq=2681 Ack=604 Win=64768 Len=0
420	65.434542600	34.229.35.39	192.168.0.103	TCP	60	443 → 1511 [ACK] Seq=604 Ack=2682 Win=32000 Len=0
421	75.056809100	192.168.0.103	104.26.10.240	TCP	54	1436 → 443 [FIN, ACK] Seq=1 Ack=1 Win=1024 Len=0
422	75.066991400	104.26.10.240	192.168.0.103	TCP	54	443 → 1436 [FIN, ACK] Seq=1 Ack=2 Win=16 Len=0
423	75.067133500	192.168.0.103	104.26.10.240	TCP	54	1436 → 443 [ACK] Seq=2 Ack=2 Win=1024 Len=0
424	75.104513700	192.168.0.103	142.250.118.94	TCP	54	1437 → 80 [FIN, ACK] Seq=1 Ack=1 Win=252 Len=0
425	75.113333100	142.250.118.94	192.168.0.103	TCP	54	80 → 1437 [FIN, ACK] Seq=1 Ack=2 Win=1053 Len=0
426	75.113500600	192.168.0.103	142.250.118.94	TCP	54	1437 → 80 [ACK] Seq=2 Ack=2 Win=252 Len=0

Frame 1: Packet, 54 bytes on wire (432 bits), 54 bytes captured (432 bits) on interface 0
Ethernet II, Src: TendaTechnol_a4:85:d8 (50:2b:73:a4:85:d8), Dst: 192.168.0.103
Internet Protocol Version 4, Src: 32.195.166.127, Dst: 192.168.0.103
Transmission Control Protocol, Src Port: 443, Dst Port: 1451, Seq: 226, Ack: 2657, Win: 32256, Len: 0

```
C:\WINDOWS\system32\cmd. X + v
Microsoft Windows [Version 10.0.26200.9457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Neeshant.S>nmap localhost
Starting Nmap 7.991 ( https://nmap.org ) at 2026-09-16 19:19 +0530
Warning: Hostname localhost resolves to 2 IPs. Using 127.0.0.1.
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
1042/tcp  open  afrog
7778/tcp  open  interwise

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds

C:\Users\Neeshant.S>
```

Risk Summary

Critical: Command Injection (9.8)

High: Brute Force Authentication (8.1)

Medium: Security Misconfiguration (6.5)

Medium: Open Ports Exposure (5.3)